

NIST CSF 2.0 Cybersecurity Risk Assessment

Maple Financial Services — Simulated Portfolio Assessment

GRC / IT Risk portfolio project | September 24, 2026

Executive Summary

This simulated assessment evaluates the cybersecurity posture of Maple Financial Services, a fictional financial-services organization with approximately 500 employees. Selected NIST CSF 2.0 Categories were used to characterize a Current State, define a Target State, identify gaps, prioritize risks, and develop remediation actions.

NIST CSF 2.0 is a taxonomy of high-level cybersecurity outcomes rather than a prescriptive control checklist. NIST's Organizational Profile guidance supports comparing a Current Profile with a Target Profile, analyzing gaps, and creating an action plan. This project follows that approach while using a separate qualitative 5x5 risk-scoring method for the simulated exercise.

Metric	Result
CSF Categories Assessed	22
Identified Gaps	19
Critical Risks	1
High Risks	6
Medium Risks	1

1. Scope and Methodology

- Organization: Maple Financial Services (fictional)
- Industry: Financial services
- Scope: Online banking, corporate IT, IAM, cloud infrastructure, critical applications and customer information.
- Out of scope: Physical security, non-IT operations and detailed secure software development lifecycle assessment.
- All organizational facts, evidence assumptions, findings, ratings and recommendations are fictional.
- Scope the assessment.
- Select relevant CSF 2.0 Categories.
- Document Current and Target States.
- Analyze gaps.
- Translate material gaps into business-relevant risks.
- Score likelihood × impact using a 1–5 qualitative scale.
- Assign treatment, ownership and remediation windows.
- Report results to stakeholders.

2. Key Findings

Theme	Observation	Priority
Identity & Access	MFA, access certification and least privilege require strengthening.	Critical / High
Data Security	Encryption and access-monitoring coverage should be verified.	High
Third-Party Risk	Vendor assessment and monitoring should be standardized.	High
Monitoring	Centralized logging and alert-triage SLAs should be expanded.	High
Resilience	Recovery testing and resilience practices should be strengthened.	High

3. Material Risk Register

ID	Risk	L	I	Score	Rating	Owner
R-001	Unauthorized access to employee accounts	4	5	20	Critical	IAM
R-002	Customer data exposure	3	5	15	High	Security
R-003	Ransomware disruption	3	5	15	High	IT/Security
R-004	Third-party security incident	3	4	12	High	GRC
R-005	Delayed incident detection	3	4	12	High	SOC
R-006	Excessive user privileges	4	4	16	High	IAM
R-007	Asset visibility gaps	3	4	12	High	IT
R-008	Delayed regulatory reporting	2	4	8	Medium	Legal/Security

Risk scoring note: Score = Likelihood × Impact. The 5x5 scoring model is a portfolio methodology for this simulation and is not prescribed by NIST CSF 2.0.

4. Remediation Roadmap

Priority	Action	Owner	Window
Critical	Implement phishing-resistant MFA for privileged/high-risk access	IAM	0–90 days
High	Implement quarterly access certification and least-privilege review	IAM	0–90 days
High	Verify encryption and monitoring coverage for critical data	Security	0–90 days
High	Create centralized enterprise asset inventory	IT	0–90 days
High	Expand monitoring and conduct recovery exercises	IT/Security	31–120 days
High	Implement standardized third-party risk assessment	GRC	31–120 days
High	Centralize logging and define alert triage SLAs	SOC	31–120 days
Medium	Document regulatory incident reporting workflow	Legal/Security	61–120 days

5. Conclusion

The largest simulated exposure areas are identity and access management, data protection, third-party risk, security monitoring, and resilience. The roadmap prioritizes access control and high-impact data/security weaknesses, followed by monitoring, vendor risk management and recovery improvements.

This portfolio project demonstrates a repeatable GRC workflow: understand business context, assess cybersecurity posture, identify gaps, translate gaps into business risk, prioritize remediation, assign ownership, and communicate results.

6. References

- NIST CSWP 29, The NIST Cybersecurity Framework (CSF) 2.0, February 2024.
- NIST SP 1301, Cybersecurity Framework 2.0: Quick-Start Guide for Creating and Using Organizational Profiles, February 2024.
- NIST CSF 2.0 Reference Tool.

Official sources: <https://csrc.nist.gov/pubs/cswp/29/final> | <https://csrc.nist.gov/pubs/sp/1301/final> | <https://csrc.nist.gov/projects/cybersecurity-framework/filters>